

SAAS MULTICLÍNICA

Matriz de perfis e permissões

Visão ilustrada dos acessos por perfil, operações CRUD, módulos contratados e pontos que ainda exigem decisão de produto.

5

perfis existentes

35

operações representativas

175

verificações de autorização

100%

testes aprovados

Tenant-scoped

Dados limitados à clínica selecionada.

Plano Parcial

Módulos desmarcados ficam ocultos e retornam 403.

Escopo médico

Pacientes e faturamentos seguem vínculos e grupos.

SuperAdministrador

Administra a plataforma, respeitando o plano operacional.

PERFIS DA APLICAÇÃO

Quem pode fazer o quê na API?

C = cadastrar · R = visualizar · U = alterar · D = excluir/desativar. "Escopo" significa que o usuário só alcança registros relacionados a ele.

Administrador

Gestão operacional completa da clínica.

Médicos

Atendimento dentro do escopo médico.

Pacientes

Acesso pessoal e restrito.

Controller

Operação clínica e financeira.

SuperAdministrador

Gestão global da plataforma.

Recurso	Administrador	Médicos	Pacientes	Controller	SuperAdministrador
Dashboard	R	R	R	R	R
Clínicas	—	—	—	—	CRUD + troca
Auditoria da plataforma	—	—	—	—	R
Usuários	CRUD	R/U próprio	R próprio	R próprio	CRUD
Pacientes	CRUD	CRU · escopo	—	CRU	CRUD
Arquivos e observações	CRU/D	CRU · escopo	—	CRU	CRU/D
Faturamento médico	R clínica	R · escopo	—	R clínica	R clínica
Grupos médicos	CRUD	—	—	Somente C	CRUD
Agenda e notificações	CRUD clínica	CRUD próprio	CRUD próprio	CRUD próprio	CRUD clínica
CBHPM	R + importar	R	R	R	R + importar
Licenças médicas	R/U/liberar	R própria	—	R própria	R/U/liberar
Exportações	Solicitar	Solicitar	Solicitar	Solicitar	Solicitar

● permitido ● permitido com limite/escopo ● negado ● função exclusiva de plataforma

EXPERIÊNCIA DO USUÁRIO

Itens exibidos no menu e no dashboard

Um item marcado ainda depende de estar contratado quando a clínica utiliza o plano Parcial.

Item visual	Administrador	Médicos	Pacientes	Controller	SuperAdministrador
Painel	✓	✓	✓	✓	✓
Usuários	✓	—	—	—	✓
Meu cadastro	—	✓	✓	—	—
Pacientes	✓	✓	✓*	✓	✓
Faturamento médico	✓	✓	—	✓	✓
Grupos médicos	✓	—	—	—*	✓
Agenda e notificações	✓	✓	✓	—*	✓
Clínicas	—	—	—	—	✓
Configuração	✓	—	—	—	✓

Regra de exclusão

- Clínica: desativação lógica, somente SuperAdministrador.
- Usuários e pacientes: somente Administrador e SuperAdministrador.
- Médico pode alterar paciente do escopo, mas não excluí-lo.
- Evento: proprietário gerencia o próprio; administradores gerenciam a clínica.

Leitura e alteração de usuário

- Administrador e SuperAdministrador gerenciam todos da clínica.
- Médico consulta e altera o próprio cadastro.
- Paciente e Controller consultam o próprio cadastro.
- Paciente atualmente não consegue salvar alterações do próprio cadastro pela API.

Os itens com * representam divergências entre a interface e a autorização efetiva da API, detalhadas na última página.

Como funciona o plano Parcial

A seleção feita no CRUD da clínica controla simultaneamente a interface e a proteção das rotas da API.



PONTOS DE ATENÇÃO

Divergências encontradas pelos testes

Esses pontos precisam de decisão funcional antes de alterar as permissões, pois envolvem comportamento de produto.

Situação	Interface atual	API atual	Recomendação/decisão	Risco
Paciente em Pacientes	Exibe o módulo como leitura.	Bloqueia a listagem com 403.	Mostrar apenas o próprio prontuário ou remover o módulo.	UX
Paciente em Meu cadastro	Exibe edição.	Permite consulta, mas bloqueia o PUT.	Definir campos pessoais editáveis.	UX
Controller em Agenda	Menu oculto.	Permite CRUD de eventos próprios.	Liberar menu ou bloquear API.	Contrato
Controller em Grupos médicos	Módulo oculto.	Pode cadastrar, mas não listar/alterar/excluir.	Remover cadastro ou criar fluxo específico.	Inconsistente
Exportações	Depende do módulo/tela.	Todos autenticados podem solicitar três recursos.	Confirmar escopo e autorização no worker.	Segurança

Validação automatizada

- 147 aprovados Backend completo
- 107 aprovados Frontend completo
- 175 verificações Matriz de autorização CRUD

Arquivos de referência

Backend: `HemodinksAPI.Tests/ApiAuthorizationMatrixTests.cs`
Frontend: `src/app/appAccess.test.ts`
Documento detalhado: `docs/MATRIZ\_PERFIS\_PERMISSOES.md`

A API é a fonte de verdade para segurança. A interface melhora a experiência escondendo ações, mas nunca deve ser o único mecanismo de autorização.